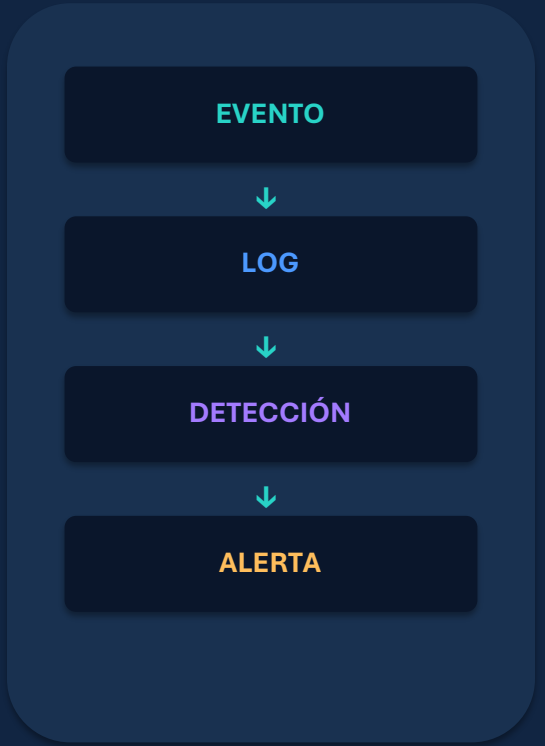
MÓDULO 7

# A09:2025 — Fallos en el Registro y Alertamiento de Seguridad

Eventos auditables · Monitoreo · Alertas · Respuesta operativa




Java JDK 17 · Jakarta EE 11 · PostgreSQL 16

# ¿Por qué importa registrar y alertar?

**La seguridad también depende de poder observar y responder.**

- Una aplicación puede ser vulnerable y además permanecer comprometida durante semanas si no produce señales útiles.
- El registro conserva evidencia; el monitoreo interpreta actividad; el alertamiento solicita una acción.
- La categoría enfatiza la alerta como mecanismo para inducir una respuesta ante eventos relevantes.

# Registro, monitoreo y alertamiento no son sinónimos

**Tres funciones conectadas, con responsabilidades distintas.**

## Registro (logging)

Captura eventos relevantes con contexto, fecha, actor, resultado y correlación.

## Monitoreo (monitoring)

Observa tendencias, patrones y desviaciones en aplicaciones, API e infraestructura.

## Alertamiento (alerting)

Convierte una condición relevante en una notificación accionable y escalable.

# Qué puede ocurrir cuando no hay registros útiles

**Sin evidencia confiable, detectar, investigar y aprender se vuelve mucho más difícil.**

- Un acceso indebido puede pasar inadvertido porque no se registran intentos fallidos ni cambios de permisos.
- Una transacción anómala puede no reconstruirse si carece de identificador de correlación y rastro de auditoría.
- Un incidente puede prolongarse si las alertas no llegan al equipo adecuado o nadie las revisa.

# Síntomas frecuentes de A09

**Antipatrones observables en aplicaciones y servicios.**

### Cobertura parcial

Solo se registran éxitos; se omiten fallas de autenticación o autorización.

### Errores silenciosos

Excepciones y advertencias no generan eventos claros.

### Sin integridad

Los registros pueden alterarse o eliminarse sin dejar evidencia.

### Sin monitoreo

Los logs existen, pero nadie analiza patrones sospechosos.

# Alertas que no generan acción

**Una alerta útil debe tener dueño, prioridad y siguiente paso.**

- No hay umbrales, responsables ni tiempos de atención definidos.
- Los avisos llegan a canales abandonados, sin confirmación ni escalamiento.
- Los playbooks están incompletos, desactualizados o no corresponden al evento detectado.
- El exceso de falsos positivos produce fatiga y hace que las alertas importantes se ignoren.

# Qué debe registrarse: autenticación

**Registrar tanto resultados exitosos como fallidos.**

## Inicio de sesión exitoso

Cuenta o identificador seudonimizado, hora, resultado y contexto técnico pertinente.

## Inicio de sesión fallido

Motivo general, cuenta objetivo, origen y señales de repetición.

## MFA y recuperación

Desafíos, fallas, cambios de factores y recuperación de cuenta.

## Sesiones

Creación, renovación, revocación y eventos anómalos.

# Qué debe registrarse: autorización y validación

**Los controles de seguridad deben producir eventos tanto al permitir como al denegar.**

- Denegaciones de acceso a recursos y operaciones protegidas.
- Fallos de validación de entradas del lado del servidor, con tipo de regla y contexto seguro.
- Cambios de roles, privilegios, permisos y políticas de acceso.
- Acceso a recursos sensibles cuando el caso de uso requiera trazabilidad.

# Qué debe registrarse: transacciones relevantes

**Ejemplo de sistema financiero hipotético.**

### Operaciones de alto valor

Identificador de operación, actor, resultado, importe o banda según clasificación.

### Cambios de beneficiario

Quién solicitó, quién autorizó, estado y marcas de tiempo.

### Cambios administrativos

Altas, bajas, modificaciones de parámetros y permisos.

### Operaciones fallidas

Errores, reversas y cancelaciones con causa normalizada.

# Advertencias, errores y excepciones

**Un error visible para el sistema debe dejar una señal útil para investigar.**

- Los errores relevantes deben producir eventos comprensibles y estructurados.
- Registrar el tipo de excepción y el punto lógico del proceso, evitando detalles internos explotables.
- No convertir fallas de seguridad en respuestas silenciosas o genéricas sin evidencia interna.
- Correlacionar el error con la solicitud o transacción que lo originó.

# Contexto mínimo de un evento

**Campos recomendados como punto de partida; adaptar al riesgo y a la política de datos.**

### Cuándo

Timestamp consistente, zona horaria o UTC y precisión definida.

### Quién

Identificador interno o seudónimo del actor; tipo de identidad.

### Qué

Acción, recurso, resultado y código de evento.

### Dónde / cómo

Servicio, entorno, origen técnico permitido y correlation ID.

# Formato estructurado para análisis

**Los registros deben ser legibles por personas y procesables por herramientas.**

- Usar nombres de campos estables, tipos previsibles y catálogos de eventos documentados.
- Normalizar niveles de severidad y resultados; evitar texto libre como única fuente de significado.
- Incluir versión del esquema para evolucionar sin romper consumidores.

# Datos sensibles: qué no debe terminar en logs

**CWE-532: la información sensible en logs puede convertirse en una nueva brecha.**

- No registrar contraseñas, secretos, tokens de sesión, claves privadas ni credenciales.
- Evitar datos personales o financieros completos cuando no sean necesarios para el propósito de auditoría.
- Enmascarar, truncar o seudonimizar identificadores cuando sea suficiente para correlación.
- Revisar también trazas, mensajes de excepción, cabeceras HTTP y datos de depuración.

# Retención, respaldo y disponibilidad

**La ausencia inesperada de logs también puede ser un evento de seguridad.**

- Definir retención según riesgo, necesidades de investigación, regulación y capacidad.
- Respaldar los registros relevantes y probar restauración y legibilidad.
- Evitar que la pérdida de un nodo elimine toda la evidencia de un periodo.
- Monitorear retrasos de ingestión, huecos de datos, cuotas y fallas de almacenamiento.